

Block 11d: refuse writes to incompatible future storage

Date: 2026-09-28. Auditor: Codex /root. Isolated checkout: /private/tmp/kk715-11a. Immediate target: fork audit/715-11c-build-review-repairs-20260928 at 659580c7cf91483c066f6ad4561290cb17b7e257 (PR #882). Code commit: 08eaa257c6730dfe0310c6a5ca89d83bf436410f. Final containing head and hosted CI belong in the PR body. Master template SHA256 at intake: 985cd8f5708e20ac34bf7442454b7ddb2271f5e9a2de048006dd75fb6f4c5556.

1. Scope and source reconciliation

This unit guards persistent operations when firmware encounters an on-flash storage format newer than it understands. The detected state intentionally looks uninitialized after boot while writes are suppressed, so seed creation or settings commands could otherwise claim success without surviving restart. The common `CHECK_STORAGE_WRITABLE` guard rejects both newer-format and Bitcoin-only incompatible storage before setup, confirmation or mutation. It covers creation starts and continuation messages, PIN and wipe-code changes, settings and policies, plus authenticator commands carried by Ping because authenticator reads may re-encrypt and persist data. Read-only Ping and Initialize remain available. The explicit WipeDevice path remains usable so the owner can erase the incompatible wallet. `storage_commit()` preserves the lock until explicit wipe.

No protocol definitions or dependency pins change. The tests use a real scratch flash image and exercise both the newer normal-band version and Bitcoin-only format. They check flash and RAM state remains untouched on refused commands, that no confirmation is requested, that ordinary read-only requests work, cancellation preserves the lock, and confirmed wipe permits later load/settings and reset/recovery flows.

2. Verification

Local full and Bitcoin-only emulator suites passed. The full firmware suite ran 699 tests; 30 focused incompatible-storage cases passed. Bitcoin-only ran 167 firmware tests; 24 focused incompatible-storage cases passed. Both reported zero failures, errors or skips. Full/BTC native firmware XML and logs plus focused case XML and logs are preserved in 715-11d-controls-20260928.tgz.

Local check	Full	Bitcoin-only	Outcome
Firmware native	699	167	All pass, zero failures/errors/skips
Incompatible-storage cases	30	24	All pass
Write refusal	Newer normal-band and Bitcoin-only formats	Same	No staging, flash mutation or confirmation
Explicit confirmed wipe	Both formats	Both formats	Subsequent load/settings and setup paths work

Archive SHA256: 07c455d675dc8115367bd4241893aa4a166a65737b32da0d60dba57de274f292. Its manifest binds eight raw test XML/log members and hashes. These local results qualify the adjacent code commit. Exact-head hosted CI, artifact checks and Copilot review are recorded in the PR body after completion. Physical-device behavior is not claimed.

3. Adjacent inventory

Inventory base: 659580c7cf91483c066f6ad4561290cb17b7e257. Reproduce with `git diff --numstat BASE..FINAL_PR_HEAD` after the report, PDF and controls archive are committed.

Added	Deleted	Path
3	2	include/keepkey/firmware/storage.h
19	27	lib/firmware/fsm.c
6	4	lib/firmware/fsm_msg_common.h
2	2	lib/firmware/storage.c
261	1	unittests/firmware/fsm.cpp
37	0	docs/release/audit-units/715-11d-future-storage-guards-20260928.md

Added	Deleted	Path
		docs/release/audit-units/715-11d-future-storage-guards-20260928.pdf
		docs/release/audit-units/715-11d-controls-20260928.tgz